

Security of age verification systems on the internet

Matt ter Steege

`m.j.tersteeg@students.uu.nl`
Universiteit Utrecht, Utrecht, Nederland

Abstract. Online age verification has become increasingly important as governments introduce stricter regulations to protect minors from age-inappropriate content and services. This report investigates the security, privacy, and reliability of the European Union’s Age Verification Solution, and proposes technical improvements based on lessons learned from existing digital identity systems.

Traditional age verification methods, such as honour systems and credit card checks, are easily bypassed. AI-based age estimation offers speed but lacks the precision required for reliable verification. The EU Age Verification Solution addresses these shortcomings by using official identity documents combined with zero-knowledge proof technology to minimise personal data exposure.

However, an analysis of the application’s source code reveals several significant vulnerabilities: improper handling of biometric data, an unprotected PIN attempt counter, the absence of model integrity checks, a lack of tampered-device detection, and dependency on non-European technology providers. A comparative analysis with banking-sector identity verification, using ING as a case study, highlights that combining both optical and NFC document scanning strengthens verification reliability. To address these weaknesses, this report proposes replacing the mobile application entirely with a government-hosted web solution using FIDO2 passkey technology. This approach eliminates the need for on-device face recognition, reduces dependency on third-party platforms, and provides a more privacy-preserving and tamper-resistant verification flow. Survey data collected among Dutch young adults further indicates moderate public support for age verification, alongside significant privacy concerns.

1 Introduction

The internet was originally built around anonymity and unrestricted access. This means that online services had little to no reliable way of determining who their users actually were. The time when simple legislation came, websites were only required to use simple age “verification” methods that were easy to bypass.

Over the last decade, governments have started taking online child safety more seriously. Legislation such as COPPA (section 2) in the United States and the United Kingdom’s Online Safety Act 2023 introduced stricter requirements for online platforms regarding age-restricted content and services. This created

a major technical problem: how can an online service verify the age of a user without collecting excessive personal data?

Modern age verification systems attempt to solve this problem through different technologies, ranging from AI-based age estimation using face scans to the European Union’s Age Digital Identity Wallet. The latter is one of the most ambitious attempts so far. One of its subsystems, the Age Verification System, promises privacy-preserving age verification through cryptographic techniques such as zero-knowledge proofs, while minimising personal data shared with online services.

This report investigates the security and privacy implications of modern online age verification systems, with a particular focus on the European Union’s Age Verification Solution. The central research question is:

“How can the security, privacy, and reliability of the European Union’s Age Verification Solution be improved through technical design choices and lessons learned from existing digital identity verification systems?”

This research question will be answered by the following sub-questions:

- *What technologies are currently used for online age verification?*
- *What mechanisms are implemented in the EU Age Verification Solution?*
- *What vulnerabilities and limitations exist in the current architecture?*
- *Which design principles from banking-sector identity verification systems could mitigate these weaknesses?*
- *What technical improvements can be proposed for future implementations?*

To answer that question, this report first examines the security and privacy aspects of online age verification systems, with a particular focus on the European Union’s Age Verification Solution. The report analyses traditional age verification and AI-based age estimation methods, and the technical architecture of the EU Age Verification App in the current implementation. Furthermore, several security weaknesses are examined, followed by a comparison with verification approaches used in the banking sector. Finally, the report proposes technical improvements and discusses the broader ethical and societal implications of large-scale digital identity systems.

2 Background

COPPA was one of the first notable child safety bills that passed the US Congress in 1998 [11]. This law was put in place to make sure that parents are in control over what information is collected from their (young) child(ren) by online services that are targeted at children aged under 13. This law seeks to protect the information of children who are under 13 years old. Later on, this law was revised by COPPA 2.0, which passed the Senate, but (as of May 2026) has not been accepted by the House of Representatives [14].

Another bill that left a bigger mark on child safety is the UK’s Online Safety Act 2023. This act was partially created to prevent children from encountering harmful or age-inappropriate content and enforce strict age checks [15]. These sets of laws are regulated by Ofcom¹.

At last, the act that was made for Europe, the Digital Service Act (DSA), is combined with the Audiovisual Media Services Directive (AVMSD). These frameworks are complementary; they make sure that minors are protected from harmful content and certain types of advertisements (alcohol, junk food, etc.). The frameworks essentially make sure that the online services that also operate in the European Union are required to protect children and disallow illegal content [12,13].

This, however, begs the question: how does one check if a user of an online service is actually past a certain age, albeit 13, 17, or 18 years old?

2.1 Traditional Age Verification

For a very long time, online services used methods that checked the age of users where not all that high-tech. Since most legislation was not all that strict on what was allowed to happen on the internet, it was not that hard to comply with. This gave rise to a couple of types of “verification” methods. These methods ranged from surface-level checks to more rigorous verification methods. One of the most well-known checks is the so-called “honour systems”, these age verification systems depend on the honesty of the end user. Most commonly, services ask for the date of birth (as seen in Figure 1) of an end user or a simple “I am 18 years old or older” button to allow access to an online service.

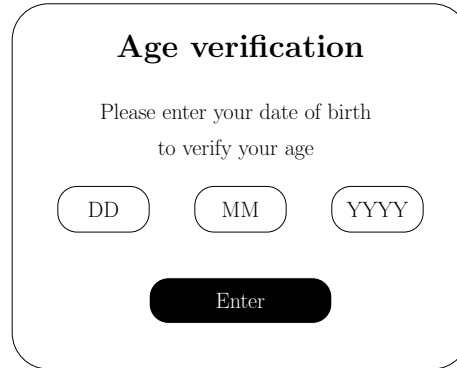


Fig. 1. Example of an honour system

These systems are, weirdly enough, not that secure. It is quite easy for any underage child to pretend that he or she is over the minimum age required to

¹ The Office of Communications

visit said online service. This defeats the purpose of having age verification at all.

Another low-tech solution that was (and still is) used quite often is credit card verification. These systems are built upon the idea that credit cards are only issued to adults. This, however, is not a good system either, since a good portion of underage children can legitimately have a personal credit card [6]. Besides, a lot of credit card issuers have so-called “test card numbers” which are valid credit card numbers [10], security codes and expiry dates which (sometimes) can be used to access restricted content.

2.2 AI-Based Age Estimation Systems

First, a subtle clarification: there is a difference between age verification and age estimation. The first confirms the exact age of a user by cross-checking official documents and is extremely accurate but slower. In other words, age verification is actual proof. The latter (age estimation) is a smart guess of the user’s age; this does not give a definite answer like 23 years old, but most likely a range of 18-22 years old. The upside of age estimation is that it is really fast and relatively accurate, since there are not a lot of reasons to tell a 28-year-old and a 43-year-old apart, which makes it a relatively good option.

Age estimation is most often done by machine learning algorithms [26]. A very common approach is to, stay with me, use a deep neural network. This means that age estimation is done in roughly 4 steps [18]. The first step is the pre-processing of the image that is going to be estimated. This is not a set-in-stone practice and varies from deep learning model to deep learning model, but most of the time, this process contains cropping of the image, removing any colour in favour of black and white. When the pre-processing is done, is when the cool parts start; the face needs to be turned into mathematical values. There are 8 important “landmarks” on a human face that all have certain distances from each other, these are the mouth, cheeks, chin, eyes, nose and forehead. As people grow older, their face goes from round to more oval, so the length between the vertical landmarks can give a first clue to someone’s age. The third step is feature extraction, which means that the landmarks are examined more closely, wrinkles around the eyes, wrinkles on the forehead or cheeks that start to hang a little bit are all clues for a certain age group. The last step is giving a verdict on the age group the user is probably in. These groups could be something like < 16 , $16 - 18$, $19 - 30$, $30 - 50$, > 50 . These groups are arbitrary, since the model could be trained for different age groups; the full path is shown in Figure 2.

This way of guessing the age of a user is quite fun, and a lot of studies are trying to make perfect age estimation, but this is not secure enough to give a green or red light for buying goods or accessing age-restricted services. That’s why the European Union introduced the following idea.

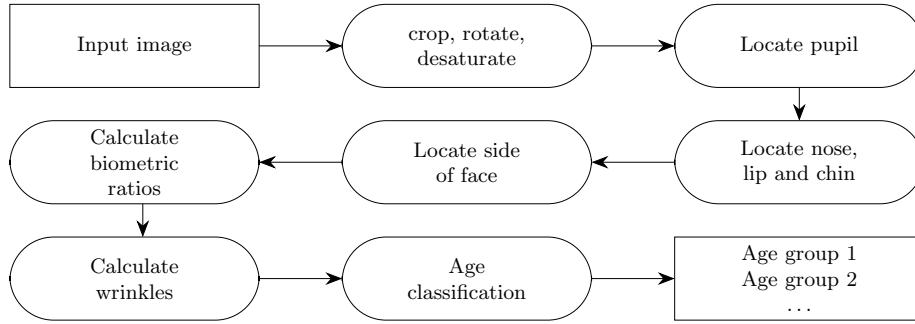


Fig. 2. Age recognition system block diagram (Adapted from [18])

2.3 EU Digital Identity Wallet

The EU digital Identity Wallet is a product of the European Union, it's created to “[create] a safe, reliable, and private mean[s] of digital identification for everyone in Europe.” [8]. Although this app contains a lot of functionality regarding payments, education credentials, and travel documents, this report only focuses on the age verification solution of the EU. This solution, named the “Age Verification Solution” (very ingenious), is the EU’s way to block underage children from visiting sites that they are not supposed/allowed to visit. But this solution is also for validating age-related benefits, or purchasing age-restricted products like alcohol or tobacco in physical or online storefronts.

The Age Verification Solution works as a so-called ZKP, a zero-knowledge proof system [17]. This means that users cannot be linked to a physical person after initial identification. This prevents user profiling and tracking as a whole, which guarantees privacy security. The European Union released a document (and example) stating the working of the app and what to keep in mind, it is meant to be implemented by each member state. The inner workings are neatly described by the European Union in the following step-by-step plan:

Activation As seen in Figure 3, the app has an activation and usage part. The activation part starts with installing the application. After that, the interesting part starts. The user requests a proof of age certificate from the designated attestation provider. This mouthful of words means the same as: the user wants to verify their age. This is done via any allowed means of verification. The application supports various options like (1) national eIDs (like the Dutch DigiD), (2) using existing trusted databases that can assure age at the highest possible level, and (3) Know Your Customer, which is a required procedure employed by banks to check the identity of their customers. The last option is (4) document-based verification, which is a way confirmation is done via official identification like ID cards, passports, driver’s licenses or any other official government-issued credentials. This does mean that the link between the document and the user

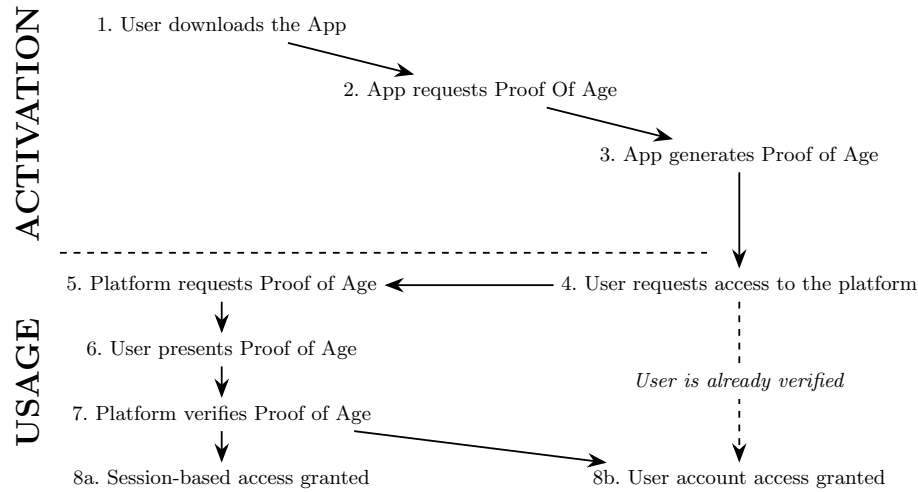


Fig. 3. Journey of a Proof of Age attestation user (taken from [17])

needs to be verified; this can be done via “liveness checks” such as a selfie or short video.

When the age of a user has been verified, then the attestation provider may issue a certificate to the installed application (and only that instance). This certificate is then securely stored within the application and can be used to verify the age of the user without letting any third party know what the exact age of the user is or any other details about the user.

Usage When the user wants to access age-restricted content/services, that service can request Proof of Age. This can be done via a same-device App integration, which means that the service requesting Proof of Age will open the age verification app. Another possibility is through the use of cross-device QR codes, where the requesting party displays a QR code that the user can scan with their mobile phone, and that will open the age verification app. After the user has the age verification app open, it will show basic details about the requesting party and whether or not the user wants to share details about being underage or not to said party. Assuming the user agrees, then the transaction proceeds, and the age verification app transmits the Proof of Age certificate to the requesting service. When the proof has been received, it is then checked against the attestation provider to test that this proof has not been forged. When this all checks out, and the user is allowed to use the service. The service may decide to make this a session, thus requiring the user to verify every time the service shall be used. An other option is saving the attestation to a user account, and thus saving the user from re-verifying every time the service is used.

technical details The application does, *after* the setup is complete (spoiler for 3) put a lot of protection on user data. The application is designed in such a way that the only data stored on the device is one or more attributes that state if a user is “age_over_18” or a similar attribute stating a different age. This is due to one of the design principles that the developers held onto [17]. The application also has cloning protection, that way the stored user data (I.E. the attribute(s)) are can not be used in an unauthorised duplication of credentials. This ensures that copying credentials does not grant unauthorised parties access to services they would not otherwise would have had.

Sadly this is only writing in the specifications of the application. As will be explored further in section 3, not everything made it into the end product created by the European Union’s development team.

3 Security and privacy risks

In this technological age, we get bombarded with hacks, data breaches and data leaks. 429 million social media account were hacked globally in 2025 [21] and hackers are getting smarter every day. This means that the security of our data should be the top priority of any software developer/designer. Sadly, this did not seem to be the case for our beloved EU Age Verification app. The app’s security features were able to be bypassed through simple steps that are definitely able to be reproduced with perseverance and a YouTube video [24,19].

3.1 Handling of private data

The European Age Verification had a lot of problems before the source code became publicly available to everyone on github.com.

One such example of a violation of correct data-handling was written in `PassportLiveVideoViewModel.kt`, lines 169–190, commit `0bda457` [19]. This piece of code *should* handle what to do after a face-scan is done and returns a success, failure, or error state. When the face-scan returns a success state, the lossless PNG file of the user’s face is deleted, and the next screen is shown to set up the app further. When the user’s face does not match (enough), an error state is returned, which is then handled by showing an error to the user, but the temporary file is not deleted from the device, thus remaining vulnerable. The same happens when an exception (read unexpected error) occurs; the user is notified, but the image remains on the device without deletion. This way of handling data also conflicts with GDPR legislation, which states that requesting/processing of data identifying a natural person is only allowed when: “processed in a manner that ensures appropriate security of the personal data” [20]. Although this is not a catastrophic privacy breach, it does not spark trust in initiatives like this.

3.2 Protecting the Proof of Age

When the user sets up the account and thus sets up a PIN code to open the app, there is an attempt counter added to the “SharedPreferences” file, which is a

settings file in which data is stored in plaintext. This counter is added to protect users from repeated checking of PIN codes, so an attacker can not just try every PIN code to gain access to the account. Sadly, this counter is not protected at all and allows the counter to be changed quite easily. The code for this can be found in `PrefsPinStorageProvider.kt`, lines 96–100, commit `5b32fe9` [19]. This means that when the maximum number of tries is reached, the attacker can reset the counter back to zero and try some other combinations, effectively bypassing the security of the PIN code. To be fair, this is only easily done on “rooted” devices, but as stated in 3.4, this is not much of a protection either.

3.3 Integrity risks

Another risk was found in `ModelDownloader.kt`, lines 85–142, commit `0bda457` [19]. This piece of code downloads the face embedding model, which essentially checks if the face image embedded in the scanned document (ID, passport, etc.) matches the selfie to verify the document matches the user. But the app allows the model to be fetched from the internet through HTTP, which is a less secure way to access resources on the internet. After the model is fetched, it is not checked through a checksum. This allows malicious actors to alter the original model in such a way that every check returns a positive result, thus making the selfie verification entirely dismantled.

3.4 Tampered-device detection

The application does not have any tamper detection for rooted devices or emulators. This means that any user can, without any form of obstruction, alter the files used by the age verification app. This is, as stated before, extra bad for tampering with devices that are not from the original owner. This way, a stolen phone can be rooted, and the verified attestation can be used. Although this does not seem very likely, it should be handled with care. As of the current latest version of the age verification app `6d97ea4` [19], this has not been fixed.

3.5 Dependency on non-European countries

As written in the introduction file about the Age verification app (`README.md`, lines 52–52, commit `b58c2cd` [19]), the app was supposed to implement “App and device verification based on Google Play Integrity API and Apple App Attestation.” This means that the application would call these API’s on Android and iOS through the Integrity API and App attestation, respectively. These make sure that the application is not using modified binaries, that the app is installed via the official Play/app store and that the device is a genuine Android/iPhone [9,7]. This, however, means that an application created by the European Union has to depend on technology from American Soil. This would strengthen the position of American (mega) corporations vis-à-vis the European Union.

Another statement written in the application specifications is the following: “An Age Verification App made available as a mobile application SHOULD

be published on the App Stores for Android and iOS operating systems and MAY be published on other App Stores (e.g. Huawei, Samsung)” as stated in `architecture-and-technical-specifications.md`, lines 1055–1057, commit `5eb8a03` [17]. The SHOULD here states that the application should be published on the Google Play Store and the Apple App store, both of which need an account for Google and Apple respectively. This means that a user who does not want to be linked to a mega-corporation like Google and Apple is not positioned in a situation where usage is possible.

The European self does not want to further deepen the dependency on American companies and the US government (or to be precise, companies and governments not in the European Union). A prime example is the Cloud Sovereignty Framework [16], which makes sure that data and infrastructure remain under the legal and regulatory control of the country or region where they reside (i.e. the European Union). For an upcoming European application that has to process personal data [20], it is not okay to be dependent on non-European countries and governments.

4 Comparative analysis

This section compares age verification approaches used in banking applications with the EU Age Verification Solution. Since European banks are required to comply with European standards, this is a great opportunity to compare with a prominent Dutch bank: ING. ING started in 1991 from a fusion between the insurer Nationale-Nederlanden and the NMB Postbank Groep. After the fusion, a new name was needed. This name, which translates to “International Netherlands Group”, was first used. Now only ING is used, since it is a lot more memorable.

4.1 Comparison criteria

Since banks have to follow the anti-money laundering and combating the financing of terrorism laws created by the European Union [22]. Opening a banking account is very similar between banks. For the purpose of demonstrating how such a procedure mostly goes, ING has been chosen as an example. It is possible that, when opening a bank account, the steps are in a different order. The minimum, as required by European law, is described. Only ING will be compared against the main way of age verification through the European Age Verification App (document scanning). The following criteria will be tested as shown in the following list:

- (1) **Identity disclosure requirements:** Which personal attributes must be disclosed during verification,
- (2) **Verification method:** How identity or age is verified, including document scanning, biometrics, and liveness detection,
- (3) **Biometric processing:** Which biometric techniques are used and for what purpose,
- (4) **Data minimization:** Whether selective disclosure or attribute-based

verification is possible, (5) **Third-party dependencies**: Which online external providers (which process user data) participate in verification or biometric processing, (6) **Persistence of identity**: Whether the verification establishes a persistent identity relationship, (7) **Regulatory justification**: Which legal or regulatory requirements justify the verification process, (8) **Privacy implications**: Potential privacy risks resulting from biometric and identity processing.

4.2 Findings

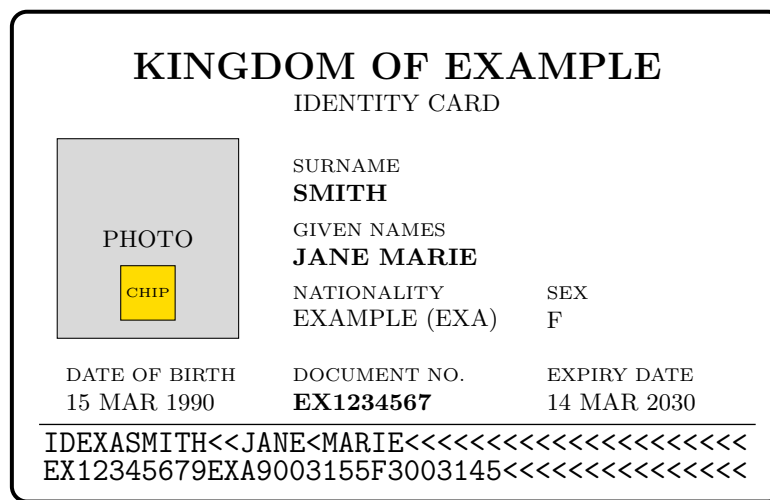


Fig. 4. Simplified figure of an ID card with Machine Readable Zone (MRZ)

Age Verification App The way the European Age verification App verifies the user’s age is through either optical character recognition of the machine-readable zones (MRZ), which are the 2 lines at the bottom of Figure 4 with the “<” (less-than) signs, by using the device’s camera. The second option would be through contactless NFC (Near Field Communication) communication with the chip that is in most identity cards and passports. The data is then verified using a checksum/data signature validation and by using cross-referencing with the issuing authority’s validation services.

Afterwards, the user has to do a live capture, which is either a selfie of video. This, let's say a selfie, is then matched with the document portrait, which has either been optically scanned in the first step, or been wirelessly transferred while scanning the document using the NFC chip. This portrait has to have a $\geq 98\%$ similarity score.

When the document is valid, official and matches the user who is trying to set up the Age Verification App. The birthdate is extracted from the MRZ written in YYMMDD format as shown on the second row, characters 14-19 in Figure 4.

The attestation is requested from the provider and saved on the device. This has all been defined by the Age Verification Specifications [17] section (3.3.2). The results are as follows:

	Age Verification App
Identity disclosure	All data on the NFC chip or machine-readable zone of a passport/ID-card.
Verification method	First document scanning, and later liveness detection.
Biometric processing	Facial matching of the user to the identity document.
Data minimisation	Unnecessary data is processed when scanning ID.
Third-party dependencies	Identity document issuing authority
Persistence of identity	No. After verification, only the attribute remains on the device.
Regulatory justification	DSA [12], AVMSD [13]
Privacy implications	See Section 3

Table 1. partial overview comparative analysis Age Verification App

Banks To open an ING bank account, firstly, a PIN code has to be created to open the application. This is a 5-digit code that has to be repeated. This is used to open the app and to confirm payments. Optionally, fingerprint and/or face recognition can be set up. Then the user's phone number for SMS-codes, and an email address used for tips and advertisements, when permission is granted.

After the "basic" data has been provided, the user is asked to scan the identifying document. The user is also forced to read how the data is used by the company and, if the user accepts, is then redirected to the page where the ID scan will actually happen. The user is asked to point the camera at the front of the ID card or passport to scan the MRZ. When the application accepts the data, the device asks the user to scan the NFC chip on the document by holding the document against the back of the phone. If NFC scanning is not available, then the user is asked to take a picture of the front and back of the document. After the needed data is taken from the identifying document, the user is asked to take a scan of their face. The matching of face, document and person takes around 10 minutes.

After the break, the user is asked to provide their name, birthplace, issuance date of the ID, residence country, city, zip code and house number. The user is asked to go over all the data once more and check if everything is correct. The user is also asked to provide some information on how they plan to use the account and some financial data, but this is not interesting for this analysis [4,5].

	ING (bank)
Identity disclosure	All data on the NFC chip and machine-readable zone of a passport/ID-card, facial image, living address and financial data.
Verification method	Document photo + NFC scan and liveness detection.
Biometric processing	Facial matching of the user.
Data minimisation	No, due to regulations.
Third-party dependencies	Identity document issuing authority
Persistence of identity	Yes
Regulatory justification	AML/CFT [22]
Privacy implications	After a possible cyberattack, personal data such as name and home address can be stolen by hackers.

Table 2. partial overview comparative analysis ING

All together When we compare the tables from the Age Verification App side by side, Table 3 emerges. As is clearly visible, the banking apps are far more guarded against impersonation and have more steps to prevent money launderers and financiers of terrorism from signing up for a bank account. But let’s go into more detail about the differences and which would be the “better” approach. Each comparative criterion will be discussed, if and only if there are notable differences between the Age Verification App and the banking app(s).

	Age Verification App	ING (bank)
Identity disclosure	All data on the NFC chip or machine-readable zone of a passport/ID card.	All data on the NFC chip and machine-readable zone of a passport/ID-card, facial image, living address and financial data.
Verification method	First document scanning, and later liveness detection.	Document photo + NFC scan and liveness detection.
Biometric processing	Facial matching of the user to the identity document.	Facial matching of the user.
Data minimisation	Unnecessary data is processed when scanning ID.	No, due to regulations.
Persistence of identity	No. After verification, only the attribute remains on the device.	Yes
Regulatory justification	DSA [12], AVMSD [13]	AML/CFT [22],
Privacy implications	See Section 3	After a possible cyberattack, personal data such as name and home address can be stolen by hackers.

Table 3. Total overview of comparative analysis

4.3 Differences

Between the second column (Age Verification App) and the third column (ING (bank)) are quite some differences. Both systems rely on similar identity verification ideas, but they diverge in the scope of data exposure, persistence, and risk profile.

Identity disclosure and Biometric processing The banks have to do identity checks on private servers, and not on-device as the Age Verification app does. This gives banks the benefit that users cannot alter the model(s) that match the face on a passport or ID with the selfie taken by the user. From a privacy standpoint, this is worse, since the bank has to process sensitive facial information.

The Age verification App has a more privacy-centred approach; the matching happens on-device. This has the benefit of being better for the user's privacy (if implemented correctly), but has the drawback of being influenceable by bad actors (see 3.3). This means that the output of this match can essentially not be trusted.

Verification method The main difference between the Age Verification App and the banking app is that the banking app requires the user to photograph and NFC-scan the ID card or passport of the user. The age verification app only requires the user to either optically scan or NFC chip scan the identifying document to prove who is creating an account. The double verification would not be too much to ask. It takes a very short amount of time for a user to do, and — as stated in the technical specification — should already be implemented in the application [17].

Data minimisation Banking apps have a lawful requirement to keep user data, while the Age Verification App only coincidentally processes unnecessary data.

Persistence of identity The age verification app is able to disregard any data on the device after issuing an attestation that the user is over a certain age. For banks, this is (logically) not possible, since it would make keeping track of customers very difficult, but it would also break European laws [22], so persistence of user data has to be done because of legal reasons.

Regulatory justification Europe's Age Verification App was developed as a response to the Digital Service Act [12] and the Audiovisual Media Services Directive [13]. The AVMSD Laws require online services to protect minors from harmful content (and stricter advertising rules). While the DSA is a far broader set of rules about illegal content, transparency, and risk mitigation for data safety.

Banks, on the other side, are mostly required by European banking law to know who their customers are, which needs a far bigger amount of user data to function [22].

Privacy implications While the worst that can happen when the Age Verification App is set up correctly is the leaking of a valid age attestation, which does not contain direct data tied to any human. Banks have a lot more data stored since they are required by law to know your customer (KYC) [22]. This means that the amount of data leaked is also bigger, and personal data could be stolen by hackers.

As reported by the European Banking Authority (EBA), “58% of banks noted that they had been victim of at least one cyber-attack in the second half of 2024, compared to 55% in the first half of 2024.” [1]. This shows that banks are a big target for hackers, and it is not unreasonable to think user data can be stolen in such hacks.

4.4 Main Takeaway

The main takeaway of this comparative analysis is the fact that banks require a lot more data to function in accordance with European laws [22]. But a difference that can be used in the European Age Verification app is the optical picture of an identifying document and the scanning via NFC. This means that the document is harder to forge and gives a bit more certainty that it is officially issued. This, with the already standing facial matching, makes the Age Verification more secure.

5 Technological proposals

The first proposal would be for the authentication part of the Age Verification App. This now only requires either taking a picture of an identifying document and a face scan, or NFC-scanning said document and doing a face scan. This means that for the first method (picture of ID), a paper copy of the ID should be able to trigger the application to accept, since the machine-readable zone is valid. The other way around, a digital copy of the data on the NFC chip of the card would be sufficient too, meaning in both cases you can not be sure that the user is actually using a genuine ID or passport for setting up the account, which would be desirable.

But altering the existing solution is not enough. That is why my second proposal is quite rigorous. A lot of applications started adopting a new way to sign in: FIDO2 passkeys. Passkeys are originally designed as a replacement for passwords. The design idea was that passwords can be stolen, hacked, or even guessed. Passkeys work differently; they work with a public-private key pair. A public key is a key that stays on the attestation provider’s server. This key is, and should be, accessible to anyone. The private key, on the other hand, is kept on the user’s device and should be protected strongly for user verification.

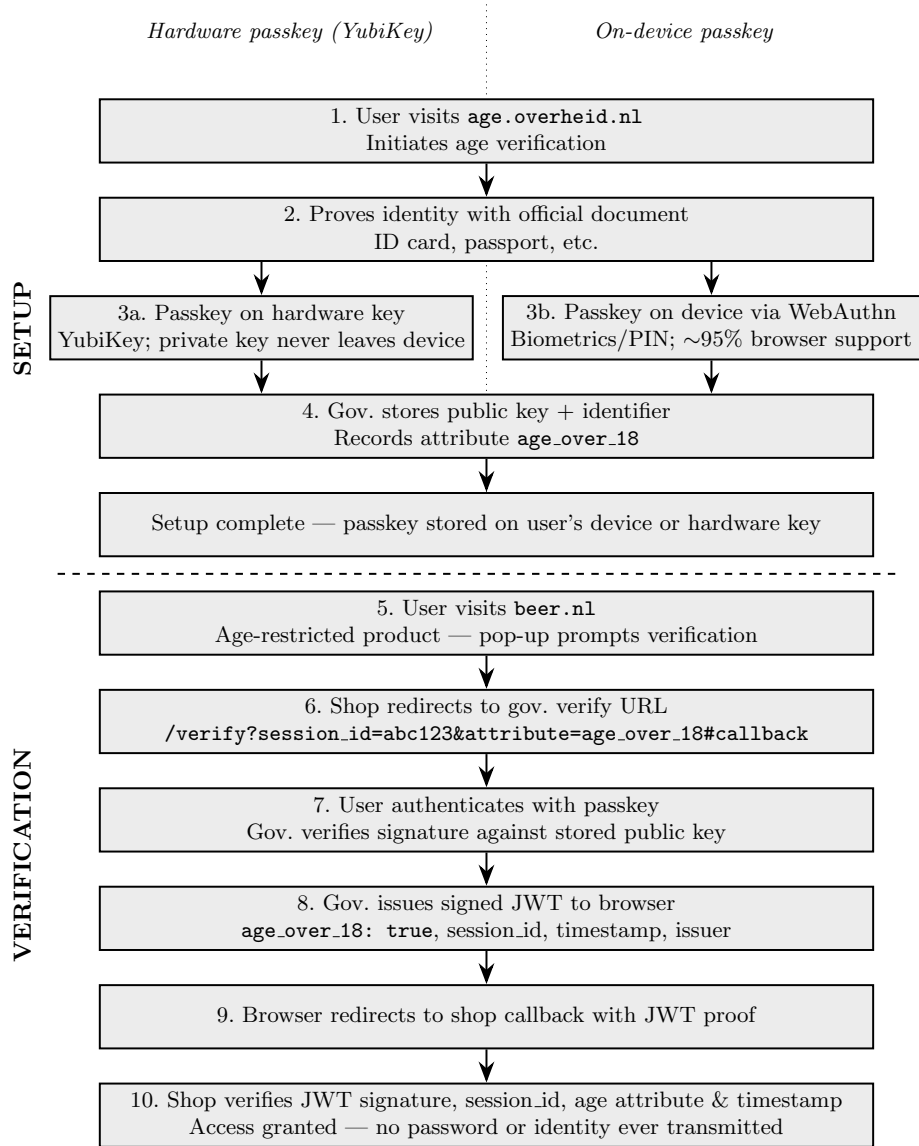


Fig. 5. Journey of a FIDO2 passkey user: government-issued age verification using hardware tokens (YubiKey) and on-device passkeys via WebAuthn.

Note: For the sake of clarity, the prefix "https://" has been omitted from all URLs listed in this section. All addresses should be accessed securely (by the user and/or age-restricted service) as https://[URL].

These passkeys are phishing-protected, since they won't work on fake websites, and they work across devices. These passkeys can be stored either on devices such as a smartphone or a dedicated hardware key like a YubiKey. Since either of the two work identical on a software level, I will refer to them as a "device". The private key is generated on the user's device and does not leave the device ever. The device also generates a corresponding public key that is sent back to the server. This process can be done by the OS or major browsers. This means that the need for an app is also not needed any more, and a website hosted by the government is more than enough. This already resolves the need for on-device face recognition (See 4.3) [2,25].

The way this system could run goes as follows (visualised in Figure 5): each European member state runs its own age verification website. For example: **age.overheid.nl**. Citizens can visit this website and prove that they are over a certain age by the official methods the member state provides (ID-card, passport, etc.). After the full age verification is done and the member state knows for sure that the user is over an age threshold, a passkey can be generated. This can be done via the browser's WebAuthn API, which supports around 95% of all global browser users [3]. The passkey is generated on the user's device and protected by biometrics or PIN or stored on a hardware key. The member state stores the public key and a random internal identifier. The member state also records that this passkey has the attribute "age_over_18" (or any arbitrary amount of attributes). The user now has a private key on the passkey that never left nor leaves the device and has a public key linked to an anonymous attestation.

After this entire setup has finished, the user owns a passkey that is securely stored on either the user's device or a hardware key. Now, since the member state has, at some point, both the public key and the user's identity, it is possible to link both together. But as will become clear later, this is not a very big issue.

*For the age verification on a third-party website, the assumption is made that the service has a backend that can securely communicate with **age.overheid.nl**.*

Now, the user wants to buy an age-restricted product, let's say alcohol at **beer.nl**. Every time the user loads the site, the user gets a pop-up covering the entire screen saying something along the lines of "Age restricted product, Age verification required". With accept and go back buttons, and a dropdown for selecting the country where the passkey is registered. The shop now redirects the user to a URL like: **age.overheid.nl/verify?session_id=abc123&attribute=age_over_18#beer.nl/callback**. Note the hash with the callback URL after it. The browser now shows the website from the member state and asks to authenticate using the passkey. The user does this, and the member state verifies the signature against the stored public key. Then the member state confirms that the user's passkey is valid and that the age is in fact over 18 years old. When the user has a proof of age, the member state's server can create a JSON Web Token (JWT) containing data like this:


```
{
  "age_over_18": true,
  "session_id": "abc123",
  "timestamp": "...",
  "issuer": "age.overheid.nl"
}
```

Code 1. (JSON) Example payload of Age Verification JWT token

This JWT is signed with the member state's private key and follows the defined specifications [23]. This JWT token is sent to the browser where the user currently is (on the member state's website). Now, here the callback URL is defined. The browser sends the user back to the requesting website with a URL like this: **beer.nl/callback?session_id=abc123&proof=eyJhbGciOi...** The shop's backend receives the proof and verifies the signature of the JWT token using the member state's public key (which can be pre-fetched and stored), checks if the session_id matches, if the age attribute is true, and checks if the timestamp is within 5 minutes (or any arbitrary amount of time). If this proof is valid, then that is it; the user can now buy all the alcoholic beverages their heart desires.

This solution also has the small benefit that users with devices that have a smaller storage capacity are still able to use this solution, since there is no application that has to be installed, and the user always has the option to delete the private key on their device, which dismantles the entire key pair.

5.1 Security

Now, why is this system private for the user? Let's assume the worst, and the member state wants to know every detail about you. So when you set up the Age Verification passkey, the member state saves the data and has linked the public key with the national identification or social security number. By design, this should not be allowed, but knowing something is not possible is better than trusting something is not done.

When **beer.nl** redirects the visiting user to **age.overheid.nl**, then the member state should not be able to see where the request comes from or where the user goes to. Because when the user authenticates, then the member state knows what website(s) a certain citizen visits.

To solve this, there are two problems to solve: Hide where the user comes from, and hide where the user goes to. The first problem can be solved by not sending the **referrer** header when **beer.nl** redirects the user to **age.overheid.nl**. This is easily achievable by simple JavaScript code:

```

var url = document.createElement("a");
url.referrerPolicy = "no-referrer";
url.rel = "noreferrer";

url.href = "age.overheid.nl/verify?session_id=abc123&attribute
=age_over_18#beer.nl/callback";
url.click();

```

Code 2. (Js) No referrer header redirect

This simple code redirects a user to a new page without telling the server where the user came from. That is the first problem solved.

The second problem (where does the user go) is also quite easily solved. As seen in the URLs presented before, the redirect is set after the # (hash) sign. When a browser redirects to a new URL (as seen in the Code 2.), all the data before the # sign is sent to the server, and everything after is only kept in the browser. The browser requests the data after the hash using simple code: `window.location.hash` → `#beer.nl/callback`. This data is only stored in the browser till the page is fully loaded, and the first JavaScript code is run. After this, the member state's authentication page can send the redirect to the server for logging/tracking purposes, but this web traffic is fully visible by the inspector window, which tracks HTTP calls and their content. Thus, essentially making this system private in the sense that it is transparent in the way the system works.

6 Ethical and societal considerations

Item	Statement	Average	Deviation	Median	α
HLV1	It is necessary for the EU to introduce age verification to protect minors online	2,89	1,29	3	0.610
HLV2	I trust the EU as the administrator of an age verification system.	2,79	1,29	3	
HLV3	I trust the Dutch government as the administrator of an age verification system.	2,5	1,23	2,5	
HLV4	I am willing to verify my age if the EU requires it.	3,36	1,42	4	
HLV5	The implementation of mandatory age verification restricts my privacy	3,07	1,39	3	
HLV6	Implementing age verification on social media is a good idea.	3,21	1,34	3	
BPD1	It doesn't bother me if websites ask for my personal data	2,14	1,01	2	0.895
BPD2	I don't think twice about providing my personal data to websites	2,07	1,02	2	
BPD3	It doesn't bother me to give my personal data to so many websites	1,96	1,04	2	
BPD4	I don't care if websites collect too much personal data about me	2,04	1,1	2	

Table 4. Survey responses ($n = 28$)

From research done together with Max Harmsen and Tom Huisman, the following data has been found regarding the willingness of users to cooperate with a European Age Verification system. The data (as seen in Table 4), 2 groups of

questions: HLV1-HLV6, which tested the attitude towards European Age Verification, and BPD1-BPD4, which tested the willingness to share privacy data. The sample consisted of Dutch respondents between 18 and 30 years old. The scale in all questions used is strongly disagree to strongly agree (1-5).

The data suggests that the respondents showed moderate support for age verification measures and are willing to comply with mandatory verification systems. However, they remain concerned about privacy implications and show relatively low trust in governmental institutions to manage such systems. Furthermore, respondents show strong awareness towards the collection and sharing of personal data. The privacy scale that measured the willingness to share data (BPD1-BPD4) has a high internal consistency ($\alpha = .895$), whereas the age verification scale (HLV1-HLV4, HLV6) showed only moderate reliability ($\alpha = .610$), suggesting that the latter may have more underlying dimensions such as trust and universal privacy concerns.

The survey results should be interpreted with caution due to the relatively small sample size ($n = 28$) and the restriction to Dutch respondents aged between 18 and 30 years. Consequently, the findings cannot be generalised to the wider European population. Nevertheless, the results provide an indication of the attitudes and concerns that may influence the adoption of age verification technologies among young adults.

7 Conclusion

This report examined the extent to which the European Age Verification System provides a secure and privacy-preserving approach to online age verification compared to traditional and AI-based age verification methods. The central question was:

“How can the security, privacy, and reliability of the European Union’s Age Verification Solution be improved through technical design choices and lessons learned from existing digital identity verification systems?”

With its five sub-questions.

To answer the first two sub-questions, research about traditional and AI-based age verification concluded that these are either too easy to bypass by users simply lying about their age, or are an estimation that does not prove someone’s real age. Although age estimation is much faster, it can not be used as a reliable source for actually proving someone’s age. The last age verification solution explored was the European solution, which uses official identifying documents to verify the user’s age via cross-checking documents. This does prove the age of a user.

The third sub-question was answered by research on the current implementation of the Age Verification solution. This showed different problems in the current state of the application’s code. The 5 privacy/security risks found are: (3.1) The handling of private data, the application does not handle user data

with enough precaution. (3.2) Protecting the Proof of Age, the application does not secure the issued proof of age sufficiently, and the app's security is easily bypassed. (3.3) Integrity risks, the application does not check if the face recognition model is original and thus can be altered by a bad actor, which makes the Proof of Age untrustworthy. (3.4) Tampered-device detection, the application does not limit rooted devices, thus allowing alteration of application data. (3.5) The last problem is dependency on non-European countries, through Google Play Integrity or Apple App Attestation, as the application depends on the US.

The systems used for banking compliance were also examined to find possible improvements for the European Age Verification system. This resulted in one main improvement: using the NFC chip in an identifying document and taking a picture of it (with liveness detection) to verify that the user has a real ID in their possession. This answered the fourth research sub-question.

The last sub-question was also answered. The technological proposal was made to discontinue the application entirely and instead opt for a website on which a user can verify and use passkey technology to keep the Proof of Age secure in an environment the user chooses (hardware keys or on-device). This solves various privacy and security risks.

All these sub-questions lead to the one single answer: replace the application with a website. This already solves security and privacy risks 3.2, 3.3, and 3.4, and solves privacy risk 3.1 when the technological proposal is implemented. And security risk 3.5 can easily be solved if the proper solutions are used.

This proposal does have some limitations; however, not all users have compatible devices or hardware keys, although this is only a very small portion of users. Furthermore, possible friction with this new system can occur for less tech-savvy people. This can be resolved with detailed documents and videos that show how to use this system; this would work as any other application/website introduction. At last, this report is only based on source code and documents. A full security audit done by a penetration testing team might reveal additional vulnerabilities or contradict some findings.

As the EU continues to build its digital identity infrastructure, the technical choices made in systems like the Age Verification Solution directly affect how citizens' data is protected. Moving toward a web-based solution that uses real identity documents, while learning from banking systems, would fix the vulnerabilities found in this report and better reflect the privacy values the EU stands for.

References

1. <https://www.eba.europa.eu/publications-and-media/publications/operational-risks-and-resilience-1>, accessed 28-05-2026
2. <https://www.passkeys.com/what-are-passkeys.html>, accessed 01-06-2026
3. <https://caniuse.com/webauthn>, accessed 02-06-2026
4. Als nieuwe klant een betaalrekening openen via de ing mobiel bankieren app, https://assets.ing.com/m/57082ca60caedd3b/original/ING_

- zo-word-je-klant-met-de-app-ing-betaalrekening-openen.pdf, accessed 26-05-2026
5. Betaalrekening openen mobiel bankieren app, https://assets.ing.com/m/60cefcd596d2cfa/1080p-Betaalrekening-openen_Mobiel-Bankieren-App.mp4, accessed 26-05-2026
 6. Credit Cards for Teens: What to Consider — Chase — chase.com. <https://www.chase.com/personal/credit-cards/education/basics/children-credit-cards>, accessed 15-05-2026
 7. DeviceCheck. <https://developer.apple.com/documentation/devicecheck>, accessed 21-05-2026
 8. EU Digital Identity Wallet Home - EU Digital Identity Wallet - — ec.europa.eu, <https://ec.europa.eu/digital-building-blocks/sites/display/EUDIGITALIDENTITYWALLET/EU+Digital+Identity+Wallet+Home>, accessed 12-05-2026
 9. Play Integrity API — Android Developers — developer.android.com. <https://developer.android.com/google/play/integrity>, accessed 21-05-2026
 10. Test card numbers — Adyen Docs — docs.adyen.com. <https://docs.adyen.com/development-resources/test-cards-and-credentials/test-card-numbers>, accessed 11-05-2026
 11. (Oct 2008), <https://web.archive.org/web/20091202093822/http://www.ftc.gov/privacy/coppafaqs.shtm>, accessed 11-05-2026
 12. Directive 2011/93/EU of the european parliament and of the council of 13 december 2011 on combating the sexual abuse and sexual exploitation of children and child pornography, and replacing council framework decision 2004/68/jha. Official Journal of the European Union **L 335**, 1–14 (12 2011), <https://eur-lex.europa.eu/eli/dir/2011/93/oj/eng>
 13. Directive (EU) 2018/1808 (Audiovisual Media Services Directive) (2018), <https://eur-lex.europa.eu/eli/dir/2018/1808/oj/eng>
 14. (Apr 2025), <https://www.congress.gov/bill/119th-congress/senate-bill/836>, accessed 11-05-2026
 15. (Apr 2025), <https://www.gov.uk/government/publications/online-safety-act-explainer/online-safety-act-explainer>, accessed 11-05-2026
 16. (Oct 2025), https://commission.europa.eu/document/download/09579818-64a6-4dd5-9577-446ab6219113_en, accessed 21-05-2026
 17. Age verification technical specification (2026), <https://ageverification.dev/av-doc-technical-specification/docs/architecture-and-technical-specifications/>, accessed 12-05-2026
 18. Dehshibi, M.M., Bastanfard, A.: A new algorithm for age recognition from facial images. *Signal Processing* **90**(8), 2431–2444 (2010). <https://doi.org/https://doi.org/10.1016/j.sigpro.2010.02.015>, <https://www.sciencedirect.com/science/article/pii/S0165168410000757>, special Section on Processing and Analysis of High-Dimensional Masses of Image and Signal Data
 19. Digital Identity, E.: av-app-android-wallet-ui (2025), <https://github.com/eu-digital-identity-wallet/av-app-android-wallet-ui>, accessed 14-05-2026
 20. European Parliament, Council of the European Union: Regulation (EU) 2016/679 of the European Parliament and of the Council, <https://data.europa.eu/eli/reg/2016/679/oj>, accessed 18-05-2026
 21. House, N.: Social media hacking statistics [2026] (May 2026), <https://app.stationx.net/articles/social-media-hacking-statistics>

22. Joint Committee of the European Supervisory Authorities: Final report on draft joint regulatory technical standards on the measures credit institutions and financial institutions shall take to mitigate the risk of money laundering and terrorist financing where a third country's law does not permit the application of group-wide policies and procedures. Final Report JC 2017 25, European Banking Authority (EBA), European Insurance and Occupational Pensions Authority (EIOPA), European Securities and Markets Authority (ESMA) (dec 2017), https://www.eba.europa.eu/sites/default/files/document_library/Publications/Draft%20Technical%20Standards/2017/JC%20RTS%20on%20the%20implementation%20of%20group%20wide%20AML-CFT%20policies%20in%20third%20countries%20/1035746/Final%20Report%20on%20Joint%20RTS%20on%203rd%20countries.pdf, accessed 27-05-2026
23. Jones, M.B., Bradley, J., Sakimura, N.: JSON Web Token (JWT). RFC 7519, RFC Editor (May 2015). <https://doi.org/10.17487/RFC7519>, <https://www.rfc-editor.org/info/rfc7519>
24. Marzolf, , O'Regan, E., Gkritsi, E.: Brussels launched an age checking app. hackers say it takes 2 minutes to break it. (Apr 2026), <https://www.politico.eu/article/eu-brussels-launched-age-checking-app-hackers-say-took-them-2-minutes-break-it/>, accessed 13-05-2026
25. Miller, M., Jones, M., Lundberg, E., Kumar, A., Cappalli, T.: Web authentication: An API for accessing public key credentials - level 3. W3C working draft, W3C (May 2026), <https://www.w3.org/TR/2026/CR-webauthn-3-20260526/>
26. Zaghbani, S., Boujneh, N., Bouhlel, M.S.: Age estimation using deep learning. *Computers Electrical Engineering* **68**, 337–347 (2018). <https://doi.org/https://doi.org/10.1016/j.compeleceng.2018.04.012>, <https://www.sciencedirect.com/science/article/pii/S0045790617334298>

AI usage

For this report, the AI chatbot ChatGPT has been used to scan through documents for relevant information. The results have been verified by checking if the result exists and if the result is relevant to what was researched. ChatGPT has essentially been used to scan large amounts of text in a faster manner than could be done by a human. No word written in his report has, at some point, been the output of an AI chatbot. ChatGPT is also used to generate the beautiful figures in this report.